

Exercício 5 — Diferença entre CWE e CVE

O que é CWE e como ele difere do CVE?

Por que ambos são importantes na segurança cibernética?

5. Diferença entre CWE e CVE

O que é CWE?

CWE (Common Weakness Enumeration — Enumeração de Fraquezas Comuns) é um catálogo de **tipos de fraquezas** existentes em softwares e hardwares.

Ele descreve a *categoria da falha* — não uma vulnerabilidade específica, mas a **causa raiz** por trás dela.

Gerenciado pela MITRE, assim como o CVE.

CWE vs CVE — A Diferença Central

	CWE	CVE
O que é	Um tipo de fraqueza	Uma vulnerabilidade específica
Nível	Genérico (a causa)	Específico (a instância)
Exemplo	CWE-79: Cross-Site Scripting	CVE-2021-44228: Log4Shell
Pergunta que responde	Que tipo de falha é essa?	Qual é exatamente esta vulnerabilidade?
Usado para		

CWE	CVE
Codificação segura, treinamento, análise de causa raiz	Gestão de patches, inteligência de ameaças

A Analogia Mais Simples

Pense como na medicina:

- **CWE** = a *categoria da doença* → "infecção respiratória"
- **CVE** = o *diagnóstico específico* → "O paciente X tem pneumonia causada pela bactéria Y"

Um descreve a classe do problema. O outro descreve a instância exata.

Exemplo Real Conectando os Dois

```
CWE-89 – Injeção de SQL (o tipo de fraqueza)
|
└─> CVE-2012-1823 – Injeção de SQL no PHP-CGI (a instância específica)
```

O CVE diz *o que estava vulnerável e quando*. O CWE diz *por que estava vulnerável* (validação inadequada de entrada).

Por que Ambos São Importantes na Segurança Cibernética?

O CWE é importante porque:

- Ajuda desenvolvedores a **evitar escrever código vulnerável** desde o início.
- Treinamentos e revisões de código seguro são organizados em torno das categorias CWE.
- Ferramentas de segurança (scanners SAST) usam CWE para classificar suas descobertas.

O CVE é importante porque:

- Fornece um **ID único e universal** para rastrear e corrigir uma falha específica.
 - Usado por scanners de vulnerabilidade, SIEMs e ferramentas de gestão de patches.
 - Permite o **compartilhamento de inteligência de ameaças** entre organizações e fornecedores.
-

Resumo

CVE diz que existe uma vulnerabilidade específica no produto X. **CWE** diz por que essa vulnerabilidade existe — e como evitar criá-las novamente.

CVE é reativo. CWE é preventivo. Você precisa dos dois.